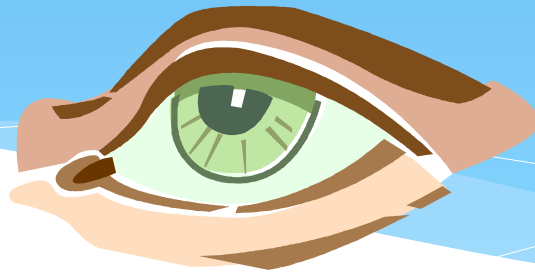


Segurança de Sistemas e dados

Aula 3

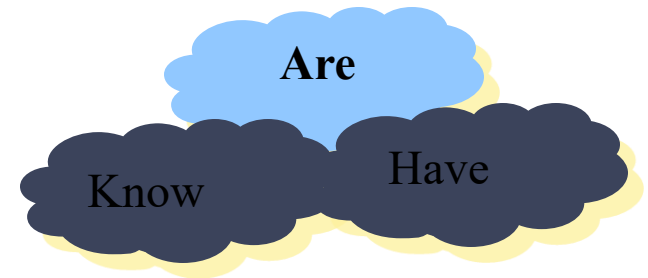
Manuel E. Correia
DCC – FCUP
mdcorrei@fc.up.pt

Biometrics



Something You Are

- * Biometric
 - * **“You are your key”** — Schneier
- * Examples
 - * Fingerprint
 - * Handwritten signature
 - * Facial recognition
 - * Speech recognition
 - * Gait (walking) recognition
 - * “Digital doggie” (odor recognition)
 - * Many more!



Something You Are

Worldcoin iris biometrics cryptocurrency project launched by Sam Altman

🕒 Oct 25, 2021, 3:03 pm EDT | [Alessandro Mascellino](#)

CATEGORIES [Biometrics News](#) | [Financial Services](#) | [Iris / Eye Recognition](#)



Tech millionaire Sam Altman's Worldcoin start-up has emerged from stealth mode, offering free cryptocurrency to individuals who verify their accounts by taking an iris scan via a dedicated biometric device.

At the time of writing, and days after its official launch, Worldcoin's valuation has already reached \$1 billion, after substantial investments from Andreessen Horowitz, Coinbase, and LinkedIn Co-founder Reid Hoffman.

The start-up was founded by Altman, together with theoretical physics student Alex Blania and investment expert Max Novendstern.

[Worldcoin](#) has already shipped its orb-shaped iris biometric devices to testers in 12 countries, with over 100,000 users globally already, and reportedly 700 more each week.

Biometric Authentication

- * authenticate user based on one of their physical characteristics

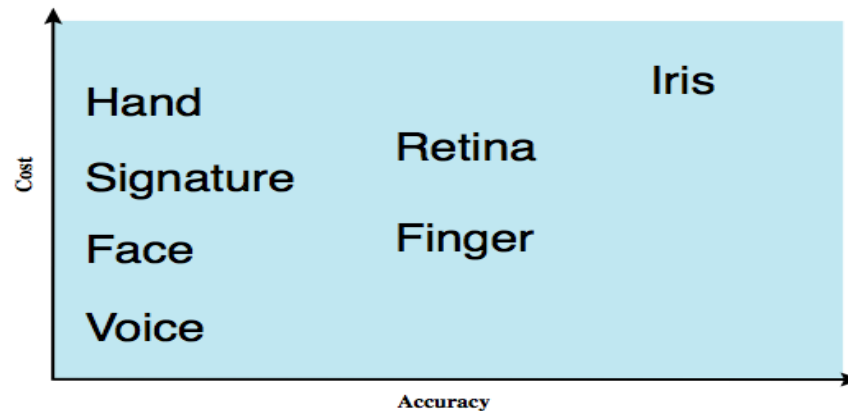


Figure 3.6 Cost versus accuracy of various biometric characteristics in user authentication schemes.

Ideal Biometric

- * **Universal** — applies to (almost) everyone
 - * In reality, no biometric applies to everyone
- * **Distinguishing** — distinguish with certainty
 - * In reality, cannot hope for 100% certainty
- * **Permanent** — physical characteristic being measured never changes
 - * In reality, OK if it to remains valid for long time
- * **Collectable** — easy to collect required data
 - * Depends on whether subjects are cooperative
- * Safe, user-friendly, etc., etc.

Biometric Modes

- * **Identification** — Who goes there?
 - * Compare **one-to-many**
 - * Example: The FBI fingerprint database
- * **Authentication** — Are you who you say you are?
 - * Compare **one-to-one**
 - * Example: Thumbprint mouse
- * Identification problem is more difficult
 - * More “random” matches since more comparisons
- * We are interested in authentication

Cooperative Subjects?

- * Authentication — cooperative subjects
- * Identification — uncooperative subjects
- * For example, facial recognition
 - * Used in Las Vegas casinos to detect known cheaters (terrorists in airports, etc.)
 - * Often do not have ideal enrollment conditions
 - * Subject will try to confuse recognition phase
- * Cooperative subject makes it much easier
 - * We are focused on authentication
 - * So, subjects are generally cooperative

Biometric Accuracy

- * never get identical templates
- * problems of false match / false non-match

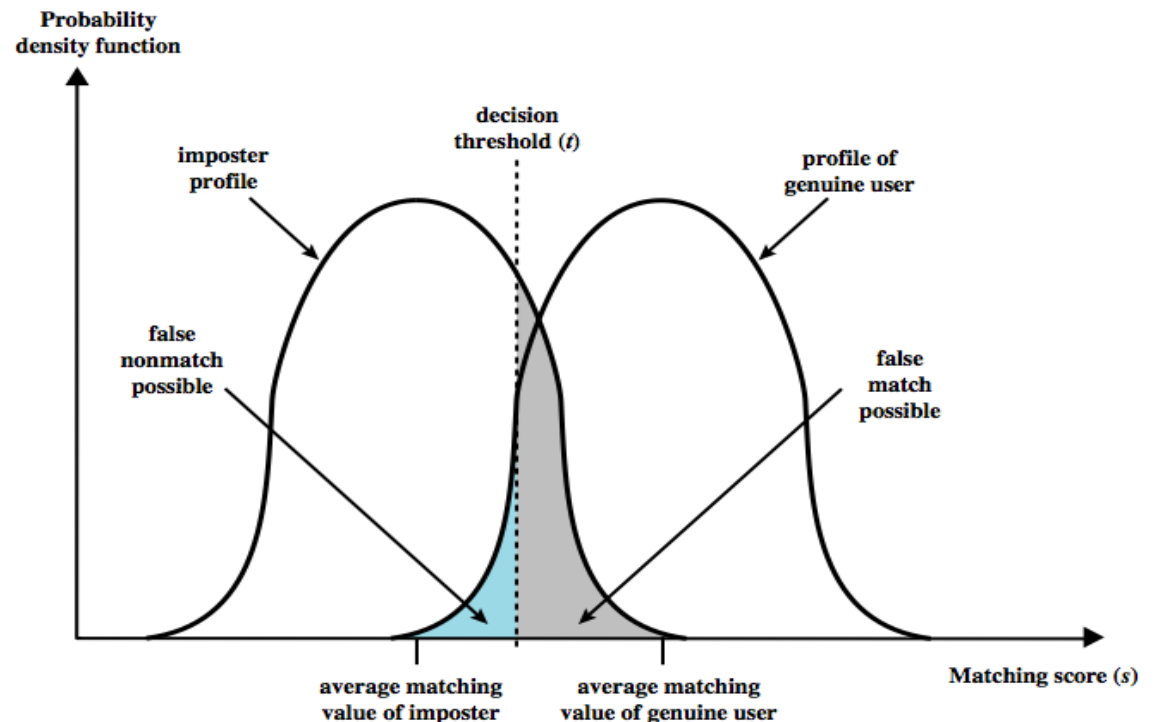


Figure 3.8 Profiles of a biometric characteristic of an imposter and an authorized users. In this depiction, the comparison between presented feature and a reference feature is reduced to a single numeric value. If the input value (s) is greater than a preassigned threshold (t), a match is declared.

Biometric Errors

- * Fraud rate versus insult rate
 - * **Fraud:** Trudy mis-authenticated as Alice (**False Positive (FP)**)
 - * **Insult:** Alice not authenticated as Alice (**False Negative (FN)**)
- * For any biometric, can decrease fraud or insult, but other one will increase
- * For example
 - * 99% voiceprint match: low fraud, high insult
 - * 30% voiceprint match: high fraud, low insult
- * **Equal error rate: rate where fraud == insult**
 - * A way to compare different biometrics

Biometric Accuracy

- * can plot characteristic curve
- * pick threshold balancing error rates

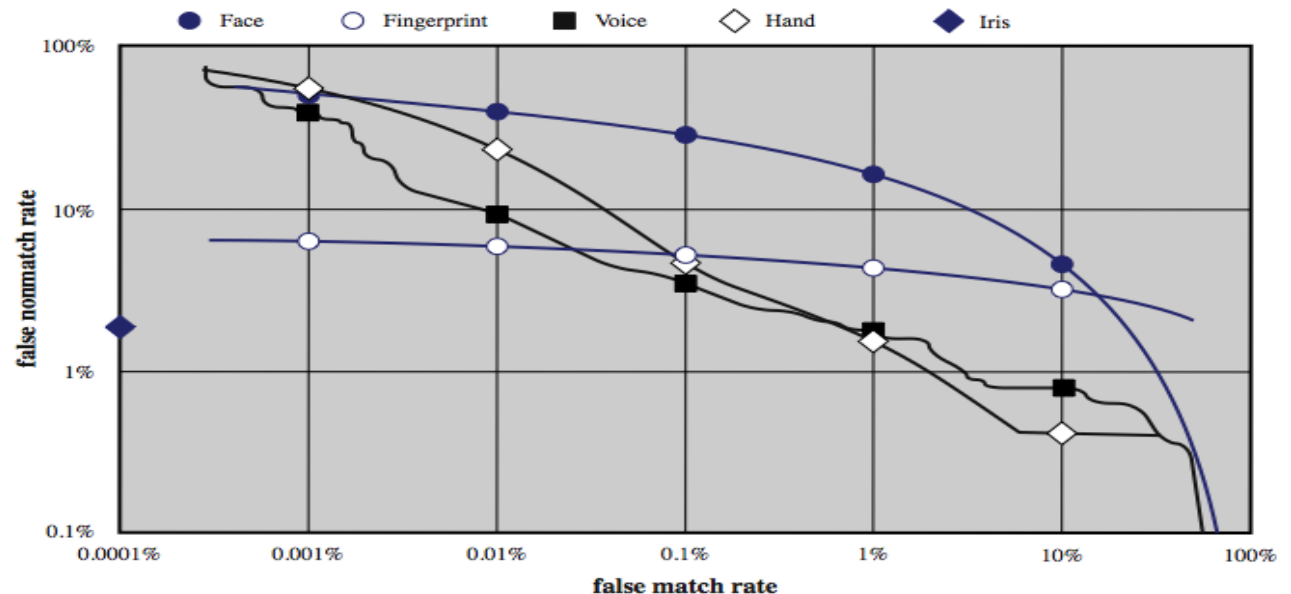


Figure 3.10 Actual biometric measurement operating characteristic curves, reported in [MANS01]. To clarify differences among systems, a log-log scale is used.

Enrollment vs Recognition

- * Enrollment phase
 - * Subject's biometric info put into database
 - * Must carefully measure the required info
 - * OK if slow and repeated measurement needed
 - * Must be very precise
 - * May be weak point of many biometric
- * Recognition phase
 - * Biometric detection, when used in practice
 - * Must be quick and simple
 - * But must be reasonably accurate

Operation of a Biometric System

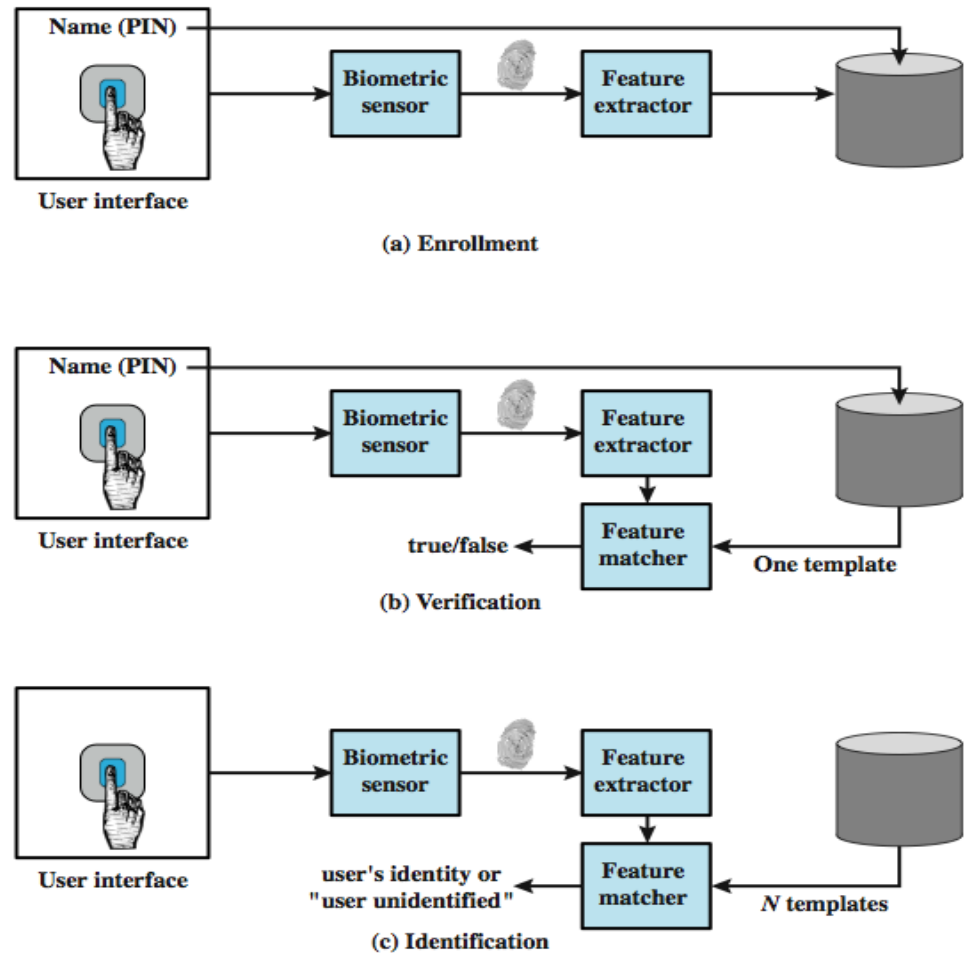


Figure 3.7 A generic biometric system. Enrollment creates an association between a user and the user's biometric characteristics. Depending on the application, user authentication either involves verifying that a claimed user is the actual user or identifying an unknown user.

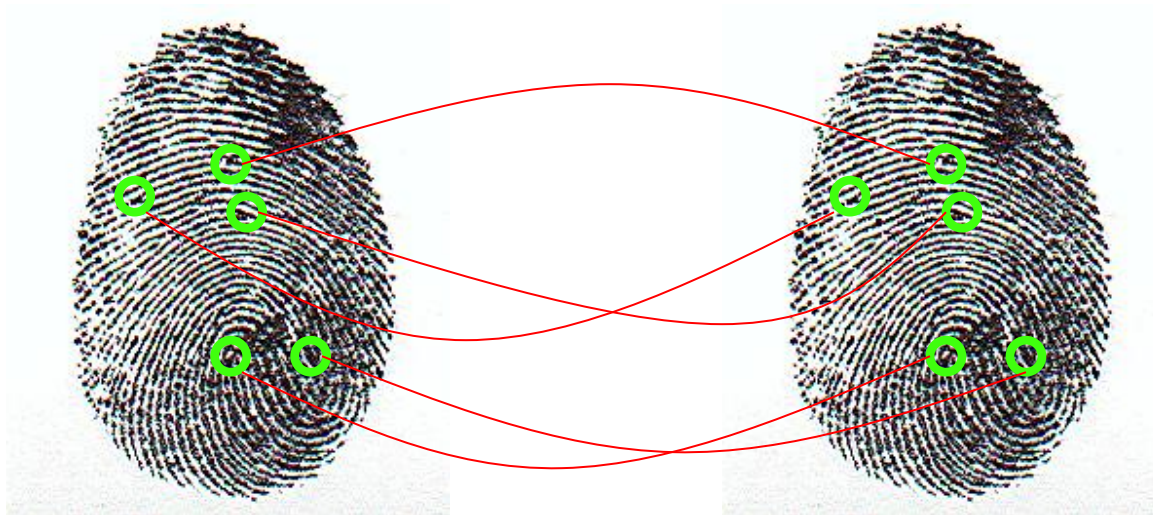
Fingerprint: Enrollment

- * Capture image of fingerprint
- * Enhance image
- * Identify points



Fingerprint: Recognition

- * Extracted points are compared with information stored in a database using statistical matching.



Hand Geometry



- ❑ A popular biometric
- ❑ Measures shape of hand
 - Width of hand, fingers
 - Length of fingers, etc.
- ❑ Human hands not unique
- ❑ Hand geometry sufficient for many situations
- ❑ OK for authentication
- ❑ Not useful for ID problem

Hand Geometry



- * Advantages



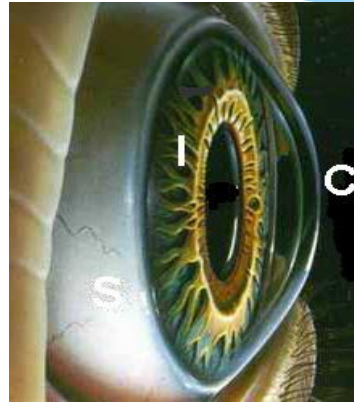
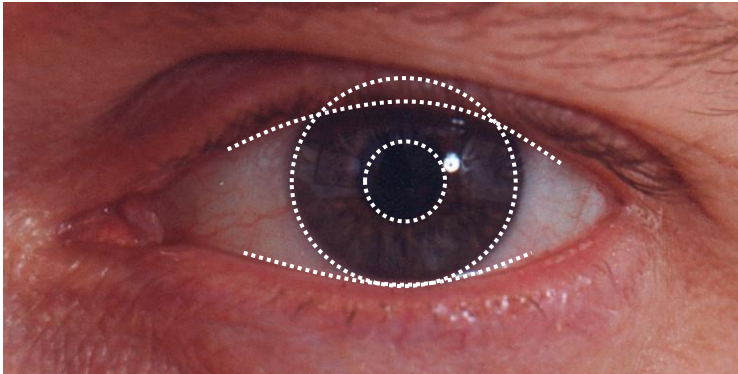
- * Quick — 1 minute for enrollment, 5 seconds for recognition
- * Hands are symmetric — so what?

- * Disadvantages



- * Cannot use on very young or very old
- * Relatively high equal error rate

Iris Patterns



- * Iris pattern development is “chaotic”
- * Little or no genetic influence
- * Different even for identical twins
- * Pattern is stable through lifetime

Iris Scan Error Rate

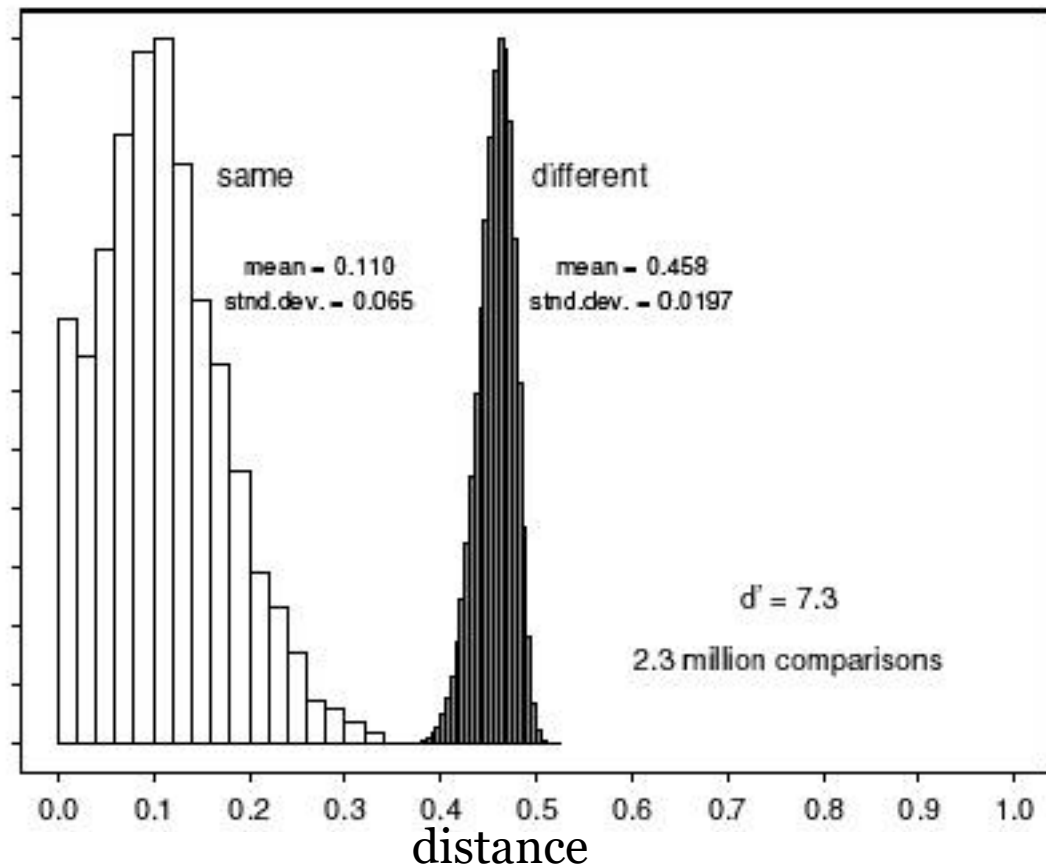
distance Fraud rate $distance = \frac{\#bits\ that\ don't\ match}{\#bits\ compared}$

0.29	1 in 1.3×10^{10}
0.30	1 in 1.5×10^9
0.31	1 in 1.8×10^8
★ 0.32	1 in 2.6×10^7
0.33	1 in 4.0×10^6
★ 0.34	1 in 6.9×10^5
0.35	1 in 1.3×10^5



equal error rate

usually used



Equal Error Rate Comparison

- * **Equal error rate (EER): fraud == insult rate**
- * **Fingerprint biometric has EER of about 5%**
- * **Hand geometry has EER of about 10^{-3}**
- * **In theory, iris scan has EER of about 10^{-6}**
 - * But in practice, may be hard to achieve
 - * Enrollment phase must be extremely accurate
- * **Most biometrics much worse than fingerprint!**
- * **Biometrics useful for authentication...**
 - * ... but identification biometrics almost useless today

Biometrics: The Bottom Line

- * Biometrics are hard to forge
- * But attacker could
 - * Steal Alice's thumb
 - * Photocopy Bob's fingerprint, eye, etc.
 - * Subvert software, database, "trusted path" ...
- * And how to revoke a "broken" biometric?
- * **Biometrics are not foolproof**
- * Biometric use is limited today
- * That should change in the (near?) future

Some devices



Something you have

Tokens

Token Authentication

- * object user possesses to authenticate, e.g.
 - * embossed card
 - * Bank random matrix codes plastic cards
 - * magnetic stripe card
 - * memory card
 - * Smartcard
 - * Smartphone App

Should be hard to copy and/or well protected.

Memory Card

- * store but do not process data
- * magnetic stripe card, e.g. old bank cards
- * electronic memory card
 - * Old phone cards
- * used alone for physical access
- * with password/PIN for computer use
- * drawbacks of memory cards include:
 - * need special reader
 - * loss of token issues
 - * user dissatisfaction

Smartcard

- * credit-card like
- * has own processor, memory, I/O ports
 - * wired or wireless access by reader
 - * may have crypto co-processor
 - * ROM, EEPROM, RAM memory
- * executes protocol to authentic reader/computer
- * also have USB dongles

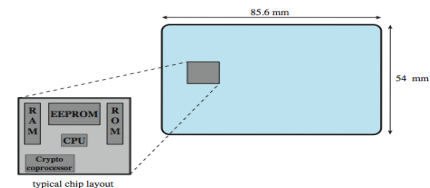


Figure 3.4 Smartcard dimensions. The smartcard chip is embedded into the plastic card and is not visible. The dimensions conform to ISO standard 7816-2

Cartão cidadão

- * BI
- * Segurança Social
- * Serviço Nacional de Saúde
- * Número de contribuinte
- * Cartão de Eleitor
- * Documento de viagem.



2-factor Authentication

- * Requires any 2 out of 3 of
 - o Something you know
 - o Something you have
 - o Something you are
- * Examples
 - * ATM: Card and PIN
 - * Credit card: Card and signature
 - * Password generator: Device and PIN
 - * Smartcard with password/PIN

Problems with Passwords Revisited

- Selection
 - Good secure passwords are hard to find
- Memorization
 - It is easy to forget infrequently used passwords
 - It is hard to remember secure passwords
- Reuse
 - Too many different passwords to memorize
 - People reuse the same password all over

Problems with Passwords in clinical settings

- * In hospitals it is common to find post-it notes with application passwords.
- * Health professionals often share accounts with each other.
 - * To cover each other backs.
 - * To circumvent hardly usable security
 - * To delegate tasks to interns.
 - * To save lives. (badly designed RBAC models and hard to use security mechanisms)
- * Keyboards are also among the dirtiest objects in the planet

Problems with Passwords Revisited

- Sharing
 - When working in groups it is common for people to share passwords
 - Non repudiation is easy to circumvent with password sharing
 - When people do not assess the real value of their digital assets they share passwords.
- Malware (Virus, Trojans)
 - Password Sniffing, Phishing Attacks, etc...

Problems with Passwords Revisited

- Online Banking is one prime example of management of highly valuable assets on the Internet.
 - Online Banks are very convenient for the costumer and save of lot money to the Banks.
 - “Phishing” attacks became widespread and are quite effective at stealing user credentials.
 - Banking dedicated Malware provides high returns to the attacker
- Risk Analysis tell us that Login/Password is not appropriate to protect these assets.

Classical Factor Two Authentication tokens

- The classic solution has been to employ factor two (difficult to clone) authentication



Classical Factor Two Authentication tokens

- * Users need to carry with them additional physical tokens and/or readers.
- * Generally, requires specific drivers and middleware software installed on users' workstations.
- * Are proprietary in Nature and incompatible with each other.
 - * Single purpose (Generally you cannot use Institution A token to authenticate yourself into Institution B).

More Flexible Factor Two Authentication tokens

* Yubikeys:

- * Low cost one time password (OTP) generator token (40 chars).
- * Connects to USB port.
- * Acts like a keyboard, no driver required.
- * Press button with your finger to generate a new OTP.
- * Very easy to integrate with legacy login/password authentication schemes.
- * Token validation service on the cloud.
- * Widely deployed by well know Internet companies (Paypal, Google, LastPass,...)
- * Direct support currently being integrated into Google chrome for a more seamless authentication with HTML5 sites.



More Flexible Factor Two Authentication tokens

- * Yubikeys:

- * Current Version has two slots. Each can store 128bits.
- * These can be used in several modes:
 - * Yubikey OTP
 - * OAUTH-HOTP (RFC 4226)
 - * Static 128 bit password
 - * Challenge Response
- * Newer models are NFC enabled.
 - * Yubikey NEO
- * Yubikey software is mostly open Source.
- * For the server side Yubico also supply a low cost HSM to securely protect shared secrets.



Yubico OTP

https://developers.yubico.com/OTP/OTPs_Explained.html

